

collaborative PP-Module for Server Applications

Acknowledgements

This collaborative Protection Profile Module (PP-Module) was developed by the iTC for Application Software international Technical Community (iTC) also known as AppSW-iTC with representatives from industry, Government agencies, Common Criteria Test Laboratories, and members of academia.

Revision History

Table 1. Revision history

Version	Date	Description
1.0	2022-04-06	Initial Release
1.0e	2024-02-15	Incorporated feedback received following initial release.

Table of Contents

Acknowledgements	1
Revision History	1
Preface	2
Objectives of Document	3
Scope of Document	3
Intended Readership	3
Related Documents	3
1. PP-Module Introduction	4
1.1. PP-Module Reference Identification	4
1.2. TOE Overview	4
1.2.1. Compliant Targets of Evaluation	4
1.3. TOE Use Cases	4
1.4. Distributed and Microservices TOE Configurations	4
2. CC Conformance Claims	5
2.1. Components allowed with this cPP in a PP-Configuration	5
3. Security Problem Definition	5
3.1. Threats	5
3.1.1. T.LOCAL_ATTACK_SERVER	5
3.1.2. T.PLATFORM_UPDATE_SERVER	6

3.1.3. T.UNTRUSTED_COMMUNICATION_CHANNELS_SERVER	6
3.1.4. Assumptions	7
3.1.5. Organizational Security Policies	7
4. Security Objectives	7
4.1. Security Objectives for the TOE	7
4.1.1. O.WELL-BEHAVED_SERVER	7
4.2. Security Objectives for the Operational Environment	7
4.2.1. OE.SECURE_LOCATION_SERVER	7
5. Security Functional Requirements	7
5.1. Conventions	7
5.2. Security Management (FMT)	8
5.3. FMT_MEC_EXT.1/Server	8
5.4. FMT_SMF.1/Server	8
5.5. Protection of the TSF (FPT)	8
5.5.1. FPT_AEX_EXT.2/Server	9
6. Security Assurance Requirements	9
Appendix A: Selection-Based Requirements	9
A.1. Identification and Authentication (FIA)	9
A.2. Protection of the TSF (FPT)	9
Appendix B: Optional Requirements	9
Appendix C: Extended Component Definitions	10
C.1. Security Management (FMT)	10
C.1.1. Family Behaviour	10
C.1.2. Component Levelling	10
C.2. Anti-Exploitation Capabilities (FPT_AEX_EXT)	11
C.2.1. Family Behaviour	11
C.2.2. Component Levelling	11
Appendix D: Consistency Rationale	11
D.1. Consistency of TOE Type	11
D.2. SFR Dependencies Analysis	12

Preface

This module is part of a Collaborative Protection Profile (cPP) whose Target of Evaluation (TOE) is software applications. Under this cPP software applications can be categorized under the following broad categories:

1. Enterprise Server Applications

This cPP-Module is to be used against which all of the above categories of software applications may be evaluated. In addition there are PP-Modules that may be applicable based on the category of application.

In addition to the above categories there are large number of applications (Desktop and Mobile) that fall under “Consumer-grade” category. While such applications could be evaluated under the Application Software cPP, it is not the intention of this iTC to specifically address this category. The iTC doesn’t believe the consumer grade app ecosystem would support the historical cost and timelines associated with a Common Criteria evaluation.

Objectives of Document

This document presents the Common Criteria (CC) collaborative Protection Profile Module (PP-Module) to express the security functional requirements (SFRs) and security assurance requirements (SARs) for Enterprise Server Applications. The Evaluation activities that specify the actions the evaluator performs to determine if a product satisfies the SFRs captured within this PP-Module, are described in [\[SD\]](#).

Scope of Document

The scope of the PP-Module within the development and evaluation process is described in the Common Criteria for Information Technology Security Evaluation. In particular, a PP-Module defines the IT security requirements of a generic type of TOE and specifies the functional security measures to be offered by that TOE to meet stated requirements [\[\[CC1\]](#), Section B.14].

Intended Readership

The target audiences of this PP-Module are developers, CC consumers, system integrators, evaluators and schemes.

Although the PP-Module and SD may contain minor editorial errors, the PP-Module is recognized as living document and the iTC is dedicated to ongoing updates and revisions. Please report any issues to the AppSW-iTC.

Related Documents

- [\[CC1\]](#) Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and General Model, CCMB-2022-11-001, CC:2022, Revision 1, November 2022.
- [\[CC2\]](#) Common Criteria for Information Technology Security Evaluation, Part 2: Security Functional Components, CCMB-2022-11-002, CC:2022, Revision 1, November 2022.
- [\[CC3\]](#) Common Criteria for Information Technology Security Evaluation, Part 3: Security Assurance Components, CCMB-2022-11-003, CC:2022, Revision 1, November 2022.
- [\[CEM\]](#) Common Methodology for Information Technology Security Evaluation, Evaluation Methodology, CCMB-2022-11-006, CC:2022, Revision 1, November 2022.
- [\[SD\]](#) Supporting Document Mandatory Technical Document: Evaluation Activities for collaborative Protection Profile Module for Server Applications, Version 1.0, February 23, 2022

For more see the [Common Criteria Portal](#).

1. PP-Module Introduction

1.1. PP-Module Reference Identification

- PP-Module Reference: collaborative PP-Module for Server Applications
- PP-Module Version: 1.0e
- PP-Module Date: 2024-02-15

1.2. TOE Overview

1.2.1. Compliant Targets of Evaluation

This is a Collaborative Protection Profile (cPP) Module whose Target of Evaluation (TOE) is Server Applications. This PP-Module is compatible with the cPP for Application Software.

For a distributed TOE, the Server Application is the TOE component, or set of TOE components, that provides management, coordination, policy, API-facing, or other server-side functionality for the TOE. In a microservices architecture, a Server Application component may be a service or application payload that coordinates, exposes, or controls TOE functionality. The container orchestration platform, container runtime, operating system, service mesh infrastructure, ingress infrastructure, cluster networking, platform-provided secret or configuration stores, managed runtimes, and application frameworks are part of the operational environment unless explicitly included in the TOE boundary.

1.3. TOE Use Cases

All use cases of Enterprise Server applications defined in the Collaborative Protection Profile for Application Software are applicable to this PP-Module.

1.4. Distributed and Microservices TOE Configurations

This PP-Module may be used in a PP-Configuration with the PP-Module for Agent Applications to evaluate distributed application software. Distributed application software includes server-agent deployments, clustered server deployments, and microservices architectures composed of multiple application payload components.

The terms Server Application and Agent Application describe TOE component roles for purposes of a PP-Configuration. They do not imply network client/server directionality, hosting relationship, privilege model, deployment topology, or that communication is initiated by one role rather than the other. A TOE component may perform one or both roles if identified in the ST.

For a distributed TOE, the ST shall identify each TOE component, describe the role of each TOE component, identify which components implement each claimed SFR, and describe all communications between TOE components. The ST shall also distinguish TOE components from operational environment components. Operational environment components may include

container orchestration, container runtimes, operating systems, service mesh infrastructure, ingress infrastructure, cluster networking, platform-provided secret or configuration stores, managed runtimes, application frameworks, and other infrastructure services not explicitly included in the TOE boundary.

If the TOE relies on operational environment components for execution, scheduling, networking, isolation, credential storage, configuration storage, time services, or protection of inter-component communications, the ST shall identify the dependency and the guidance shall describe the required environmental configuration.

2. CC Conformance Claims

As defined by the references [CC1], [CC2] and [CC3], this PP-Module:

- conforms to the requirements of Common Criteria CC:2022, Revision 1,
- is Part 2 extended,
- does not claim conformance to any other security functional requirement packages.

In order to be conformant to this PP-Module, a ST shall demonstrate Exact Conformance. Exact Conformance, as a subset of Strict Conformance as defined by the CC, is defined as the ST containing all of the SFRs in [Security Functional Requirements](#) (these are the mandatory SFRs) of this PP-Module, and potentially SFRs from [Consistency Rationale](#) (these are selection-based SFRs) and [Selection-Based Requirements](#) (these are optional SFRs) of this PP-Module. While iteration is allowed, no additional requirements (from the CC parts 2 or 3, or definitions of extended components not already included in this PP-Module) are allowed to be included in the ST. Further, no SFRs in [Security Functional Requirements](#) of this PP-Module are allowed to be omitted.

2.1. Components allowed with this cPP in a PP-Configuration

The list of packages, PP-Modules and cPPs that may be used in conjunction with this Module can be found at: https://appswcpp.github.io/cPP/AppSW_cPP_allowed-with-list.pdf

3. Security Problem Definition

The security problem is described in terms of the threats that the TOE is expected to address, assumptions about its operational environment, and any organizational security policies that the TOE is expected to enforce.

3.1. Threats

3.1.1. T.LOCAL_ATTACK_SERVER

An attacker can act through unprivileged access on the same computing platform on which the application executes. For example, attackers may provide maliciously formatted input to the

application in the form of files or other local communications thus providing unauthorized access to plaintext sensitive data.

SFR Rationale:

- FPT_AEX_EXT.2/Server ensures that the application does not subvert security mechanisms provided by the platform thereby allowing an attacker with local access to exploit the application.
- FMT_MEC_EXT.1/Server ensures that unauthorized access to application's configuration data is not possible.
- FMT_SMF.1/Server ensures that rogue or misconfigured TOE components or agents do not compromise the security of the server application.

3.1.2. T.PLATFORM_UPDATE_SERVER

Updating the platform that the application operates on could break the application's functionality. As such an end user might choose not to update the platform, thereby preventing the patching of known issues on the platform. An attacker could exploit such unpatched vulnerabilities in the platform to then mount an attack on the application.

SFR Rationale:

- FPT_AEX_EXT.2/Server SFR ensures that the TOE leverages the functionality provided and supported by the platform. This ensures that when the platform is updated, the supported functionality does not break and makes it easier to keep the platform updated without having to worry about breaking the applications running on the platform.

3.1.3. T.UNTRUSTED_COMMUNICATION_CHANNELS_SERVER

Attackers may take advantage of poorly designed or non-secure protocols or poor key management to successfully perform man-in-the middle attacks, replay attacks, etc. Successful attacks will result in loss of confidentiality and integrity of the critical network traffic, and potentially could lead to a compromise of the application itself. Attackers may attempt to target applications that do not use standardized secure tunneling protocols to protect the critical network traffic. This threat is of particular concern when an application uses protocols that have not been subject to extensive peer review. Additionally attackers may attempt to connect via untrusted entities and use that connectivity to perform various attacks.

SFR Rationale:

- FMT_SMF.1/Server ensures that the server application can manage security-relevant communication configuration with trusted IT entities or TOE components.
- FTP_DIT_EXT.1 in the Collaborative Protection Profile for Application Software ensures that communication between trusted entities or TOE components is protected using well known protocols.

3.1.4. Assumptions

All Assumptions of the Collaborative Protection Profile for Application Software apply also to this PP-Module.

3.1.5. Organizational Security Policies

There are no OSPs for applications.

4. Security Objectives

4.1. Security Objectives for the TOE

The following subsections describe objectives for the TOE. Since the Collaborative Protection Profile for Application Software does not specify any Objectives for the TOE. This section contains only additional Objectives for the TOE related to the PP-Module but independent from the Collaborative Protection Profile for Application Software.

4.1.1. O.WELL-BEHAVED_SERVER

The TOE shall not circumvent the security controls provided by the underlying platform.

SFR Rationale:

- FPT_AEX_EXT.2/Server ensures that the app is well-behaved within the narrow context of ensuring security mechanisms of the underlying platforms are not subverted.

4.2. Security Objectives for the Operational Environment

All objectives for the Operational Environment of the Collaborative Protection Profile for Application Software apply also to this PP-Module. Additionally the following objective is added to this PP-Module:

4.2.1. OE.SECURE_LOCATION_SERVER

Enterprise servers that run enterprise applications should be housed in a secure location.

5. Security Functional Requirements

5.1. Conventions

The individual security functional requirements are specified in the sections below. The following conventions are used for the completion of operations:

- [*Italicized text within square brackets*] indicates an operation to be completed by the ST author.

- **Bold text** indicates additional text provided as a refinement.
- [**Bold text within square brackets**] indicates the completion of an assignment.
- [text within square brackets] indicates the completion of a selection.
- Number in parentheses after SFR name, e.g. (1) indicates the completion of an iteration.
- '/Server' has been added to every SFR in this module to distinguish SFRs added from Server modules.

Extended SFRs are identified by having a label “EXT” at the end of the SFR name.

5.2. Security Management (FMT)

5.3. FMT_MEC_EXT.1/Server

FMT_MEC_EXT.1.1/Server Read and write access to the TOE’s configuration data shall be limited to Administrator, TOE and [assignment: *list of authorized entities*].

5.4. FMT_SMF.1/Server

FMT_SMF.1.1/Server The TSF shall be capable of performing the following management functions:

- configuration of communication with [selection: *other trusted IT entities outside the TOE, TOE components, other trusted IT entities outside the TOE and TOE components*]
- [selection:
 - *allow/disallow the enrollment of a TOE agent by administrative function or policy,*
 - *query agent version,*
 - *provide update functionality to agent,*
 - *change administrative passwords,*
 - *change agent credentials,*
 - *configure and change recovery credentials,*
 - *configure number of authentication attempts and failed authentication behavior,*
 - *[assignment: Other management functions]*

Application Note 1: Functions that relate to management of agents or other separately deployed TOE components are intended to be used in conjunction with the Agent module. The same functions may also be used with third-party entities that are in the operational environment and are not within the TOE boundary. Configuration of communication with TOE components may be performed during installation, through runtime management functions, or through another TOE-defined administrative mechanism described in the ST.

5.5. Protection of the TSF (FPT)

5.5.1. FPT_AEX_EXT.2/Server

FPT_AEX_EXT.2.1/Server The application shall be compatible with security features provided by the platform vendor.

Application Note 2: This requirement is designed to ensure that platform security features do not need to be disabled in order for the application to run. The assignment in FPT_AEX_EXT.1.3 in the Collaborative Protection Profile for Application Software must be "no exceptions".

6. Security Assurance Requirements

This PP-Module does not define any additional assurance requirements above and beyond what is defined in the Collaborative Protection Profile for Application Software that it extends. Application of the SARs to the TOE boundary described by both the claimed base and this PP-Module is sufficient to demonstrate that the claimed SFRs have been implemented correctly by the TOE.

Appendix A: Selection-Based Requirements

There are currently no Selection-Based requirements. This section may be applicable in later revisions.

A.1. Identification and Authentication (FIA)

This PP-Module does not define separate X.509 requirements. Certificate validation and certificate path processing requirements for trusted channels, inter-component communication, and other certificate-authenticated protocols are addressed by the X.509 package selected through the base cPP, where applicable.

A.2. Protection of the TSF (FPT)

This PP-Module does not define separate FPT_ITT requirements. Protection of data transmitted between TOE components is addressed by FPT_DIT_EXT.1 in the base cPP.

Appendix B: Optional Requirements

There are currently no Optional requirements. Following section may be applicable in later revisions.

Appendix C: Extended Component Definitions

This appendix contains the definitions for the extended requirements that are used in the PP-Module, including those used in [Consistency Rationale](#) and [Selection-Based Requirements](#) .

C.1. Security Management (FMT)

C.1.1. Family Behaviour

Components in this family address requirements for secure configuration. This is a new family defined for the FMT class.

C.1.2. Component Levelling

Component leveling

```
+-----+ +-----+
|  FPT_MEC_EXT Security Management  |-----|  1  |
+-----+ +-----+
```

FPT_MEC_EXT.1/Server ensures that the TOE is not vulnerable to malicious configuration changes by unauthorized access or an escalation of privilege attack.

Management: FPT_MEC_EXT.1/Server

The following actions could be considered for the management functions in FPT:

- a. There are no management activities foreseen

Audit: FPT_MEC_EXT.1/Server

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a. No audit necessary

FMT_MEC_EXT.1/Server

Hierarchical to: No other components

Dependencies: No other components

FMT_MEC_EXT.1.1/Server Read and write access to the TOE's configuration data shall be limited to Administrator, TOE and [assignment: list of authorized entities].

C.2. Anti-Exploitation Capabilities (FPT_AEX_EXT)

C.2.1. Family Behaviour

This is a new component within the FPT class which addresses requirements to ensure the TOE is not susceptible to commonly used exploitation methods. Additionally, it ensures that the application doesn't circumvent security functionality provided by the platform. This is a new family defined for the FPT class.

C.2.2. Component Levelling

Component leveling

+	-----	+		+	-----	+
	FPT_AEX_EXT Anti-Exploitation		-----		2	
+	-----	+		+	-----	+

FPT_AEX_EXT.2 ensures the TOE is not susceptible to commonly used exploitation methods and that it doesn't circumvent security functionality provided by the platform.

Management: FPT_AEX_EXT.2

The following actions could be considered for the management functions in FPT:

- a. There are no management activities foreseen

Audit: FPT_AEX_EXT.2

The following actions should be auditable if FAU_GEN Security audit data generation is included in the PP/ST:

- a. No audit necessary

FPT_AEX_EXT.2/Server

Hierarchical to: No other components

Dependencies: No other components

FPT_AEX_EXT.2.1/Server The application shall be compatible with security features provided by the platform vendor.

Appendix D: Consistency Rationale

D.1. Consistency of TOE Type

When this PP-Module is used to extend [cPP_APP_SW], the TOE type for the overall TOE is still a generic application. However, one of the functions of the device must be the ability for it to the

capability to manage agent applications. The TOE boundary is simply extended to include that functionality.

D.2. SFR Dependencies Analysis

The dependencies between SFRs implemented by the TOE are addressed as shown in the base PP.